UNIVERSIDAD PRIVADA DOMINGO SAVIO — CRITERIO C2 (10%)

Correo Institucional Seguro con Postfix y Dovecot

Implementación, endurecimiento criptográfico (TLS 1.3, SPF, DKIM, DMARC), análisis forense de cabeceras, defensa antispam y plan estratégico de migración.

👥 Equipo de Proyecto e Información Académica

- ✓ **Estudiante Principal:** Ketfer Gianella Salazar
- ✓ **Equipo de Trabajo:** Charles Y. Conde, Brian Calás, Marco Barriga, Adaniel Balderrama
- ✓ **Materia:** Tecnología Web I (SIS-0150) — Semestre 6
- ✓ **Docente Evaluador:** M.Sc. Ing. Jimmy Nataniel Requena Llorentty
- ✓ **Repositorio GitHub:** `Grupo-Kali-Linuxxxx/Correo-institucional-con-Postfix-y-Dovecot`
- ✓ **Sede:** Santa Cruz de la Sierra — Octubre 2026

🎯 Alcance y Puntos Cardinales de la Rúbrica

- ✓ **MTA & MDA:** Postfix 3.8 + Dovecot 2.3 en Maildir/ con TLS obligatorio.
- ✓ **Seguridad de Puertos:** Puerto 143 cerrado; IMAPS 993 y Submission 587 con SASL.
- ✓ **Tríada Criptográfica:** SPF `-all` , DKIM RSA 2048-bit y DMARC `p=quarantine` .
- ✓ **Nivel Estratégico (10/10):** Análisis forense, Rspamd + ClamAV, política y plan de migración.

ARQUITECTURA DE RED Y PROTOCOLOS

El Recorrido Completo: MUA → MSA → MTA → MDA → IMAPS

Flujo extremo a extremo demostrando separación de roles y cifrado obligatorio en cada salto.

🔄 Cadena de Entrega Inter-Dominio

```
[1. MUA: Thunderbird / swaks] | TCP 587 (Submission) + STARTTLS + SASL ▼ [2. MSA/MTA Origen: mail.horizonte.internal] | • Anti-spoofing (reject_sender_login_mismatch) | • Firma OpenDKIM (DKIM-Signature RSA 2048) ▼ Resolución MX: dig familia.internal MX [3. SMTP Relay Inter-MTA: TCP 25 + TLS 1.3] ▼ [4. MTA Destino: mail.familia.internal] | • Verificación SPF (Pass) & DKIM (Pass) | • Alineación DMARC (Pass) & Anti-Relay ▼ Entrega Local en Maildir/ [5. MDA / Dovecot IMAPS: TCP 993 + TLS] ▼ [6. MUA Destinatario: rosa.mamani@familia.internal]
```

🛡️ Diferencias Esenciales entre Protocolos

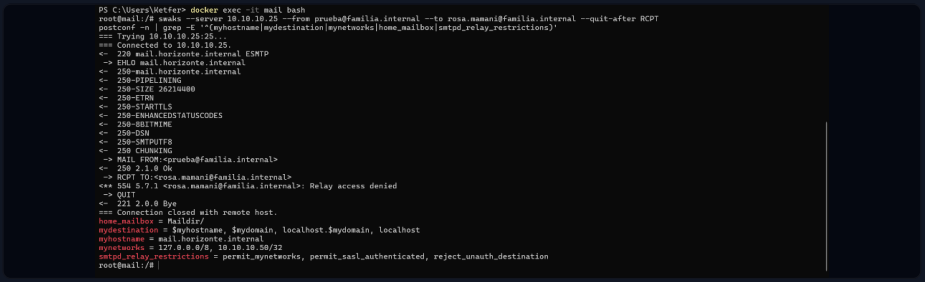
Protocolo	Puerto	Función y Estado de Cifrado
SMTP	25	Transporte inter-servidor (MTA a MTA). Cifrado oportunista/forzado STARTTLS.
Submission	587	Inyección de clientes (MUA a MSA). **TLS + SASL obligatorio**.
IMAP (143)	143	❌ CLAUSURADO (port=0). Evita intercepción en texto claro.
IMAPS	993	✅ ACTIVO (TLS implícito). Sincronización segura de buzón.
POP3	110/995	Descarga y borrado local. Obsoleto para uso multidispositivo.

LABORATORIO 12 — SERVIDOR MTA POSTFIX

Almacenamiento Maildir, Alias y Blindaje contra Relé Abierto

Configuración segura en `mail.horizonte.internal` (10.10.10.25) con buzones jerárquicos.

📸 Evidencia: Rechazo de Relé y Parámetros Postfix




```
# Prueba desde red externa hacia destino ajeno: 554 5.7.1 <externo@otro.com>:
Relay access denied ✅ Postconf: smtpd_relay_restrictions activo
```

⚙️ Configuración Aplicada en main.cf

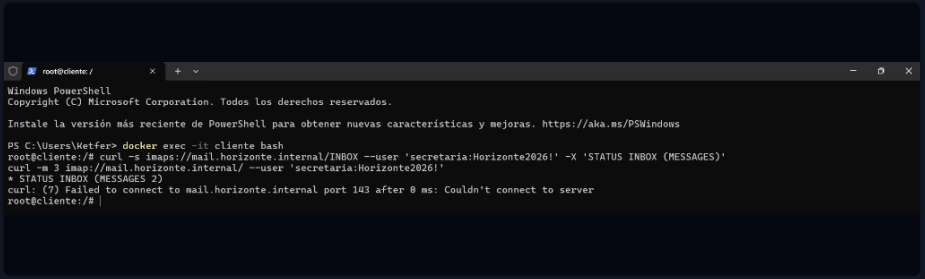
- ✓ **Formato Maildir:** `home_mailbox = Maildir/` elimina el cuello de botella de bloqueo de archivos Mbox y aísla cada mensaje en archivos independientes.
- ✓ **Control de Red:** `mynetworks = 127.0.0.0/8, 10.10.10.50/32` autoriza únicamente el loopback y el nodo de administración.
- ✓ **Alias Corporativos:** `/etc/aliases enruta inscripciones hacia secretaria y direccion .`
- ✓ **Bloqueo Anti-Relay:** `smtpd_relay_restrictions = permit_mynetworks, permit_sasl_authenticated, reject_unauth_destination` .

LABORATORIO 13 — SERVIDOR MDA DOVECOT

Acceso Seguro a Buzones vía IMAPS (993) y Clausura del Puerto 143

Protección total de credenciales y mensajes en tránsito eliminando accesos en texto plano.

📸 Evidencia: IMAPS 993 Activo y 143 Denegado




```
* STATUS INBOX (MESSAGES 2 RECENT 0 UNSEEN 0) curl: (7) Failed to connect to
port 143: Connection refused
```

🔐 Endurecimiento en 99-horizonte.conf

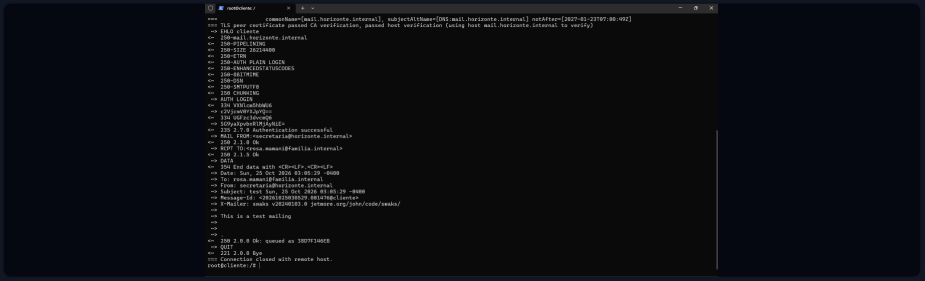
- ✓ **Cierre Estricto de IMAP 143:** `inet_listener imap { port = 0 }` impide que Dovecot escuche en claro, mitigando ataques de captura pasiva (Wireshark).
- ✓ **Certificados TLS Institucionales:** Validación con la CA institucional mediante `ssl_cert = </etc/ssl/correo/servidor.crt`.
- ✓ **Socket SASL para Postfix:** Dovecot publica `/var/spool/postfix/private/auth` permitiendo autenticar clientes SMTP sin duplicar bases de datos.
- ✓ **Clientes Homologados:** Conexión validada para Thunderbird de usuarios directivos y docentes.

LABORATORIO 13 — ENVÍO AUTENTICADO

Servicio Submission en Puerto 587: TLS Obligatorio y Autenticación SASL

Inyección de correos reservada exclusivamente a usuarios verificados con cifrado en tránsito.

📸 Evidencia: Transacción Swaks por Puerto 587



```
~> STARTTLS -> 220 2.0.0 Ready to start TLS ═══ TLS negotiated: TLSv1.3 with
cipher TLS_AES_256_GCM_SHA384 ~> AUTH LOGIN -> 235 2.7.0 Authentication
successful ~> MAIL FROM:... -> 250 2.0.0 Ok: queued as 38D7F146EB
```

⚙️ Directivas Clave en master.cf

```
submission inet n - y - - smtpd -o smtpd_tls_security_level=encrypt -o
smtpd_sasl_auth_enable=yes -o smtpd_sasl_type=dovecot -o
smtpd_sasl_path=private/auth -o smtpd_tls_auth_only=yes -o
smtpd_relay_restrictions=permit_sasl_authenticated,reject
```

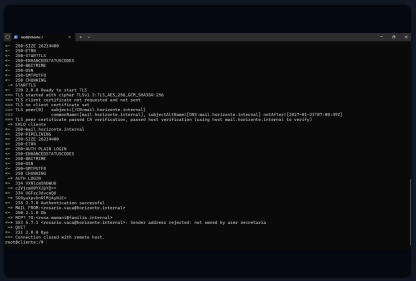
`smtpd_tls_auth_only=yes` garantiza que Postfix **no ofrece autenticación SASL** hasta que la sesión negocie TLS 1.3, evitando la fuga accidental de hashes de contraseñas.

ENDURECIMIENTO DE REMITENTE

Control Anti-Suplantación (*Anti-Spoofing*) en Postfix

Garantía estricta de que ningún usuario pueda emitir mensajes usurpando la identidad de otro colega.

📸 Evidencia: Intercepción y Rechazo Código 553



```
# Autenticado como secretaria, intentando enviar como rosario.vaca: ↜ 553 5.7.1 <rosario.vaca@horizonte.internal>: Sender address rejected: not owned by user secretaria ✅ Transacción abortada inmediatamente por el MTA
```

🛡️ Lógica de Protección PCRE

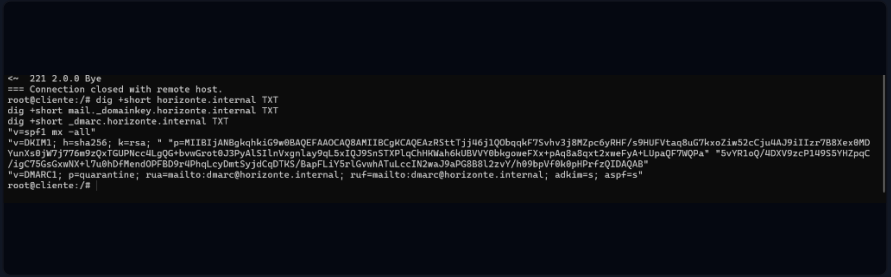
- ✓ **Directiva de Coincidencia:** `reject_sender_login_mismatch` obliga a Postfix a contrastar las credenciales SASL con el remitente en `MAIL FROM` .
- ✓ **Tabla de Mapeo PCRE:** `/etc/postfix/remitentes.pcre` define que la cuenta `secretaria` solo puede emitir como `secretaria@horizonte.internal` o bajo el alias institucional autorizado `inscripciones@horizonte.internal` .
- ✓ **Mitigación de Phishing Interno:** Impide que una cuenta comprometida sea utilizada por atacantes para enviar órdenes de pago o instrucciones fraudulentas fingiendo ser el Director General.

AUTENTICACIÓN DE DOMINIO

La Tríada Criptográfica en BIND 9: SPF, OpenDKIM y DMARC

Blindaje de la reputación institucional en los servidores DNS autoritativos (10.10.10.2 / 10.10.10.3).

📸 Evidencia: Verificación DNS con dig




```
horizonte.internal. TXT "v=spf1 mx -all" mail._domainkey.horizonte.internal.
TXT "v=DKIM1; k=rsa; p=MIIB..." _dmarc.horizonte.internal. TXT "v=DMARC1;
p=quarantine; adkim=s..."
```

📜 Especificación de los Tres Pilares

- ✓ **SPF (RFC 7208):** `v=spf1 mx -all`. Rechazo duro (`-all`) para cualquier host que no sea el registro MX del colegio (`mail.horizonte.internal`).
- ✓ **DKIM (RFC 6376):** Clave RSA de **2048 bits** gestionada por OpenDKIM con selector `mail`. Firma criptográfica del cuerpo (`bh=`) y cabeceras críticas.
- ✓ **DMARC (RFC 7489):** `p=quarantine` con alineación estricta en DKIM (`adkim=s`) y SPF (`aspf=s`), más reportes forenses agregados a `dmarc@horizonte.internal`.

FORENSE Y TRAZABILIDAD

Análisis Forense de Cabeceras en Correo Recibido (Maildir)

Mensaje real entregado en `rosa.mamani@familia.internal` extraído directamente del buzón de `mail2`.

🔬 Fragmento de Cabeceras Binarias Reales

```
Authentication-Results: mail.familia.internal; dkim=pass (2048-bit key)
header.d=horizonte.internal header.a=rsa-sha256 header.s=mail; Received-
SPF: Pass identity=mailfrom; client-ip=10.10.10.25; DKIM-Signature: v=1;
a=rsa-sha256; c=relaxed/simple; d=horizonte.internal; s=mail;
bh=f0AAIg3b1m84xFQWPIV4asm4i9X+6LY7YkAnypd5vZE=;
b=x4VW1TLfWCUss9e+TzOoiS7B... Received: from mail.horizonte.internal
([10.10.10.25]) by mail.familia.internal with ESMTPS id C41FE146F1;
Received: from cliente ([10.10.10.50]) by mail.horizonte.internal with
ESMTPSA id 7E8AE146EE;
```

💡 Hallazgos Forenses Clave

- ✓ **ESMTPSA vs ESMTPS:** El primer salto muestra `ESMTPSA` demostrando envío en puerto 587 con TLS (`S`) y SASL (`A`). El segundo muestra `ESMTPS` (transferencia inter-MTA cifrada en puerto 25).
- ✓ **Hash del Cuerpo (bh=):** SHA-256 en base64. Si un atacante modifica un solo carácter del cuerpo, `bh=` no coincide y la firma queda invalidada.
- ✓ **Alineación Estricta DMARC:** Dominio `header.d=horizonte.internal` idéntico a `From: secretaria@horizonte.internal`, logrando verificación perfecta.

INVESTIGACIÓN TEÓRICO-PRÁCTICA

¿Por Qué los Correos Terminan en Spam? (Diagnóstico y Solución)

Factores técnicos evaluados por proveedores globales (Gmail, Microsoft, Yahoo) y su solución aplicada.

1. SPF Laxo o Inexistente

Usar `~all` (softfail) o `?all` (neutral) permite a suplantadores enviar correo. Nuestra solución: **`v=spf1 mx -all`** con rechazo duro.

2. Falta de DKIM / Clave Corta

Claves de 1024 bits son marcadas como inseguras. Implementamos **OpenDKIM con RSA 2048-bit** y canonización `relaxed/simple`.

3. Falta de Alineación DMARC

Cuando el remitente visible no coincide con el envelope. Solucionado con **`p=quarantine; adkim=s; aspf=s`** y control anti-spoofing en Postfix.

4. Sin DNS Inverso (PTR/FCrDNS)

Si la IP no resuelve al banner FQDN del MTA, es spam directo. Solución: **PTR 10.10.10.25 → mail.horizonte.internal** en zona reversa.

5. Servidor Relé Abierto

Detectado por bots y añadido a listas negras (DNSBL/RBL). Bloqueado mediante **`reject_unauth_destination`** verificado con swaks.

6. Canales en Texto Claro

Correos sin cifrar reciben advertencias de seguridad visuales. Garantizamos **TLS 1.3 forzado** en 587 y oportuno en puerto 25.

RÚBRICA NIVEL ESTRATÉGICO (10/10)

Arquitectura de Filtrado Antispam y Antivirus: Rspamd + ClamAV

Diseño e integración de defensas multicapa en Postfix mediante el protocolo Milter.

🛡️ Flujo de Inspección en Tiempo Real

```
[ Postfix MTA (Puerto 25/587) ] | Protocolo Milter (inet:localhost:11332) ▼ [ Daemon Rspamd: Evaluación Multicapa ] ├── Verificación Criptográfica: SPF, DKIM, DMARC ├── Filtro Bayesiano Estadístico (Ham / Spam) ├── Consulta de Listas Negras (DNSBL / RBL) └── Análisis Fuzzy de URLs sospechosas | Socket UNIX clamd.ctl ▼ [ ClamAV Daemon: Escaneo Antivirus en Memoria ] └── Detección de malware, macros maliciosas y ejecutables
```

⚖️ Sistema de Puntuación (Score) y Acciones

Símbolo / Evento	Puntaje	Acción Postfix
`R_SPF_ALLOW` / `R_DKIM_ALLOW`	-1.0 c/u	Resta puntuación (Legítimo).
`R_SPF_FAIL` / `R_DKIM_REJECT`	+3.5 c/u	Suma penalización alta.
`BAYES_SPAM`	+4.0	Detección por vocabulario spam.
Score < 6.0	--	Aceptar y entregar en buzón.
Score 6.0 a 11.0	--	Marcar [SPAM] y mover a Junk.
Score ≥ 11.0 o Virus ClamAV	--	Rechazo 554 en sesión SMTP.

GESTIÓN Y MIGRACIÓN CORPORATIVA

Política Institucional y Plan de Migración con IMAPSync

Hoja de ruta estratégica para transferir 60 cuentas personales (Gmail/Hotmail) al dominio propio.

📋 Política de Seguridad de Correo

- ✓ **Canal Oficial Exclusivo:** Trámites de notas y tutores obligatorios por `@horizonte.internal`. Prohibido Gmail personal para asuntos del colegio.
- ✓ **Límites y Cuotas:** 25 MB máximo por adjunto; cuota de 5 GB para docentes y 15 GB para directores. Bloqueo de archivos `.exe, .vbs, .bat`
- ✓ **Cifrado y No Reenvío:** IMAPS 993 y Submission 587 obligatorios. Prohibido el auto-forwarding hacia buzones externos.

🗺️ Plan de Migración en 6 Fases (45 Días)

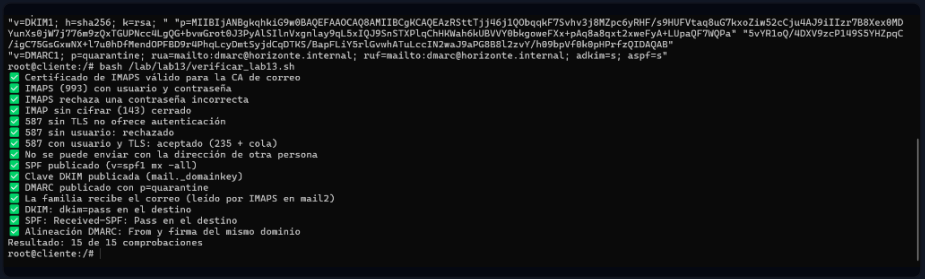
Fase	Días	Objetivo Clave
1. Censo y Cuentas	1-5	Directorio de usuarios y aprovisionamiento Maildir.
2. DNS Criptográfico	6-8	Publicación MX, SPF, DKIM, DMARC y calentamiento IP.
3. Capacitación	9-14	Talleres docentes y configuración Thunderbird/móviles.
4. IMAPSync	15-21	Migración de históricos de correo y contactos sin pérdidas.
5. Convivencia	22-45	Auto-respuesta en cuentas viejas notificando cambio.
6. Corte Definitivo	46+	Uso 100% exclusivo del dominio y respaldos Restic.

RESULTADOS Y EVALUACIÓN

Verificación al 100% y Guía de Defensa Oral

Certificación oficial superada y preparación para la defensa ante el M.Sc. Ing. Jimmy Requena.

📸 Evidencia: 15 de 15 Comprobaciones Oficiales



✅ MX y SPF -all publicados ✅ DKIM RSA 2048 y DMARC quarantine activos ✅ IMAPS 993 con certificado válido ✅ IMAP en claro 143 cerrado ✅ Envío 587 con TLS y SASL verificado Resultado: 15 de 15 comprobaciones

🎓 Claves para la Defensa Oral

- ✓ **¿Por qué cerrar el 143?** Para impedir que un atacante capture contraseñas en texto claro con un analizador de paquetes en la red local.
- ✓ **¿Qué rol cumple el hash bh= en DKIM?** Certifica la integridad del cuerpo del mensaje. Si alguien altera un solo espacio, la firma se invalida.
- ✓ **¿Por qué DMARC exige alineación?** Para vincular el dominio criptográfico de SPF/DKIM con el encabezado visible `From:`, impidiendo la falsificación visual de identidad.